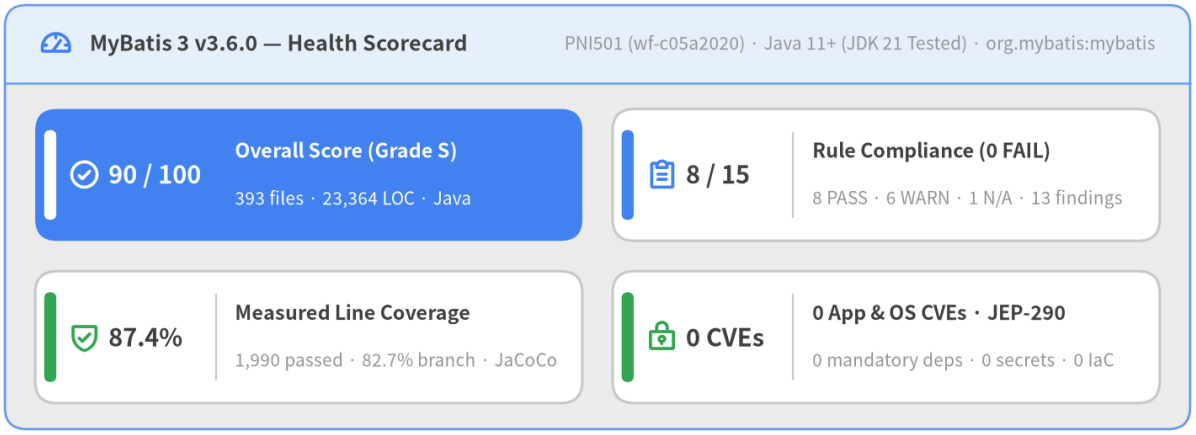
PNI Software Health Diagnostic Report

MyBatis 3 `v3.6.0` — *Automated Architecture, Static Java AST, Hermetic Runtime & Supply-Chain Diagnostic*

This independent technical showcase evaluates **MyBatis 3** `v3.6.0` (tag `mybatis-3.6.0` / commit `73a0c5d4`, Apache License 2.0) across 7 software engineering dimensions using PNI501 and Drawlib. All upstream Java packages (`org.apache.ibatis.*`), JUnit 5 test suites, and Maven build manifests are inspected unmodified in zero-pollution hermetic environments.



MyBatis 3 v3.6.0 — PNI501 Overall Engineering Health Scorecard

Diagnostic Attribute	Verified Metadata & Audit Baseline
Target Project	`mybatis3` (`v3.6.0`, tag `mybatis-3.6.0` / commit `73a0c5d4`, Maven `org.mybatis:mybatis`, Java `11+`)
Target Language & Profile	`java` (`library` — SQL mapper & relational persistence framework over standard JDBC)
Upstream License & Attribution	Apache License 2.0 (`LICENSE-MYBATIS` & `NOTICE`; Copyright © 2009–2026 MyBatis.org)
Diagnostic Workflow	`pni501` (Workflow Run ID `wf-c05a2020`, category `audit`)
Evaluated At	`2026-11-10T03:44:29+00:00` (`2026-11-10T03:44:29.163937+00:00`)
Overall Score & Grade	**90 / 100 (Grade S)** — `8 / 15` rules `PASS`, `6 WARN`, `0 FAIL`, `1 NOT_APPLICABLE` (`13` raw findings across `12` unique locations: `0` CRITICAL, `0` HIGH, `3` MEDIUM, `9` LOW, `1` INFO)

Diagnostic Attribute	Verified Metadata & Audit Baseline
Analyzed Codebase Scope	`393` Java source files (`23,364` LOC, `374` classes, `2,721` methods across `20` packages) & `372` JUnit 5 test files (`1,990` passed, `0` failed under `--network=none`)

> **Unofficial Engineering Showcase Notice**: This diagnostic report is an independent automated analysis generated with PNI501 and Drawlib to study MyBatis 3's architecture and software engineering quality, and is not affiliated with or endorsed by the official MyBatis project.

Table of Contents

1. Executive Summary

2. Architecture & Source Code Structure

3. Recommended Remediation Roadmap

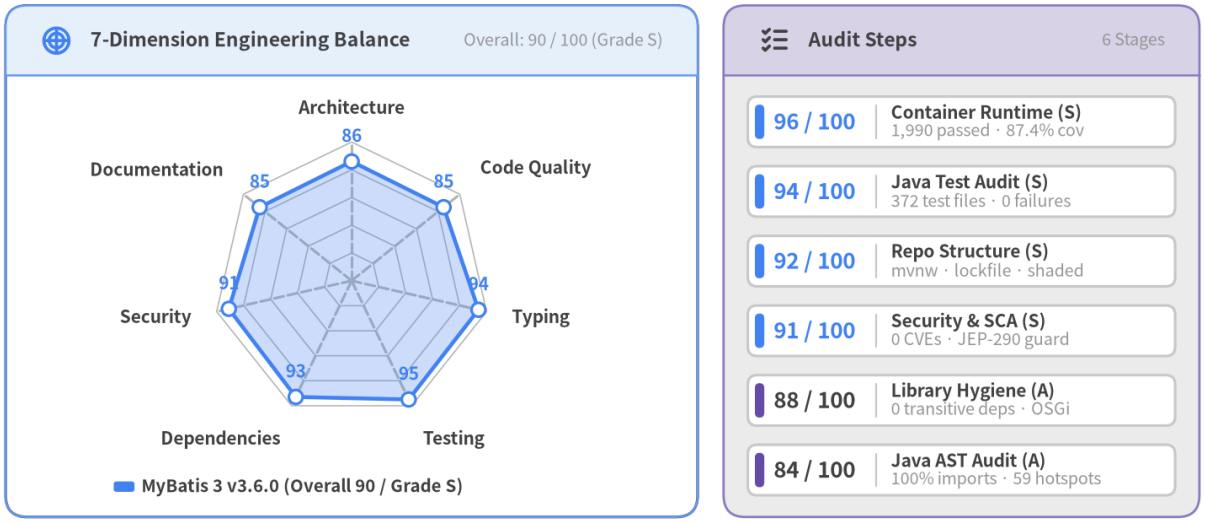
4. Audit Standards, Rule Compliance & Findings

5. Deep Dive: Code Quality, Testing & Runtime

6. Deep Dive: Security, Supply Chain & API Surface

1. Executive Summary

MyBatis 3 (`v3.6.0` , Maven artifact `org.mybatis:mybatis`) achieves an overall PNI501 engineering score of **90/100 (Grade S)** across a 15-stage static Java AST, package dependency DAG, library hygiene, hermetic Maven/JUnit 5 container runtime, and Trivy supply-chain audit. Across **393 Java source files** (**23,364 LOC**, **374 classes**, **2,721 methods**) and **372 JUnit 5 test files**, the framework demonstrates **100.0% import hygiene**, **99.9% generic type coverage**, **zero mandatory runtime dependencies** (with OGNL `3.4.16` and Javassist `3.33.0-GA` shaded into `org.apache.ibatis.*`), **zero Trivy CVEs**, and **100% offline test reliability** (`1,990` passed, `0` failed) with **87.4% measured JaCoCo line coverage** and **82.7% branch coverage**.

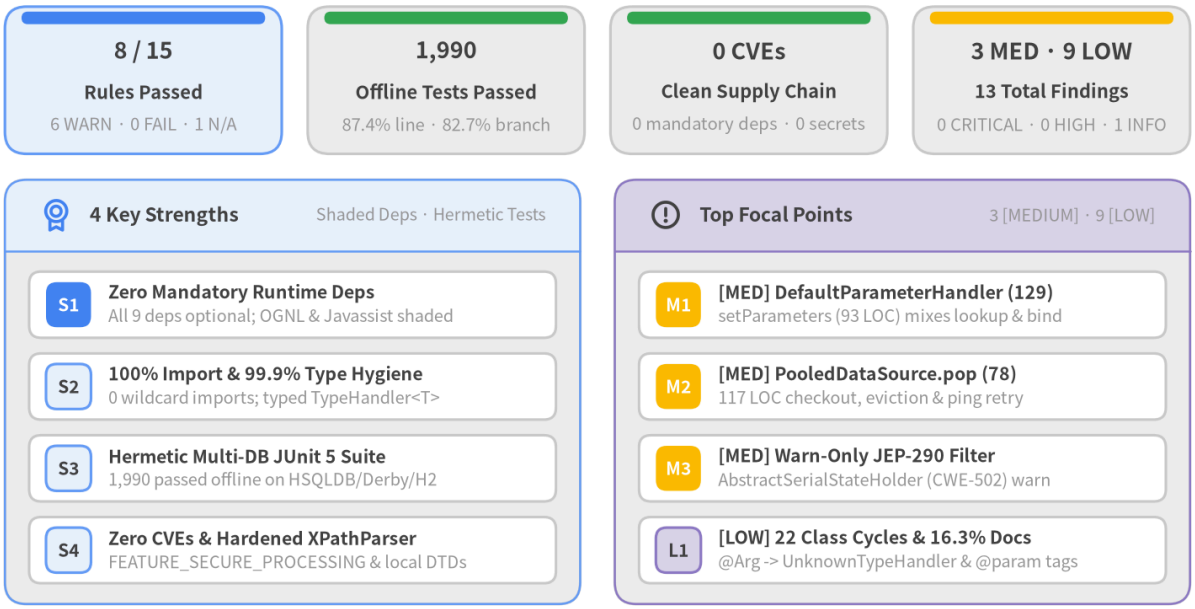


MyBatis 3 v3.6.0 — 7-Dimension Engineering Health Radar & Audit Step Scores

1.1 Headline Engineering KPIs, Key Strengths & Top Risks

The seven-axis diagnostic profile reflects a battle-tested Java library whose core design choices—zero mandatory runtime dependencies, compile-time XML/annotation lowering into `MappedStatement` registries, and strict separation between thread-safe `Configuration`

metadata and thread-confined `SqlSession` / `Executor` instances—have scaled cleanly across more than a decade of enterprise adoption.



MyBatis 3 v3.6.0 — Verified Engineering Strengths vs. Top Maintainability & Security Risks

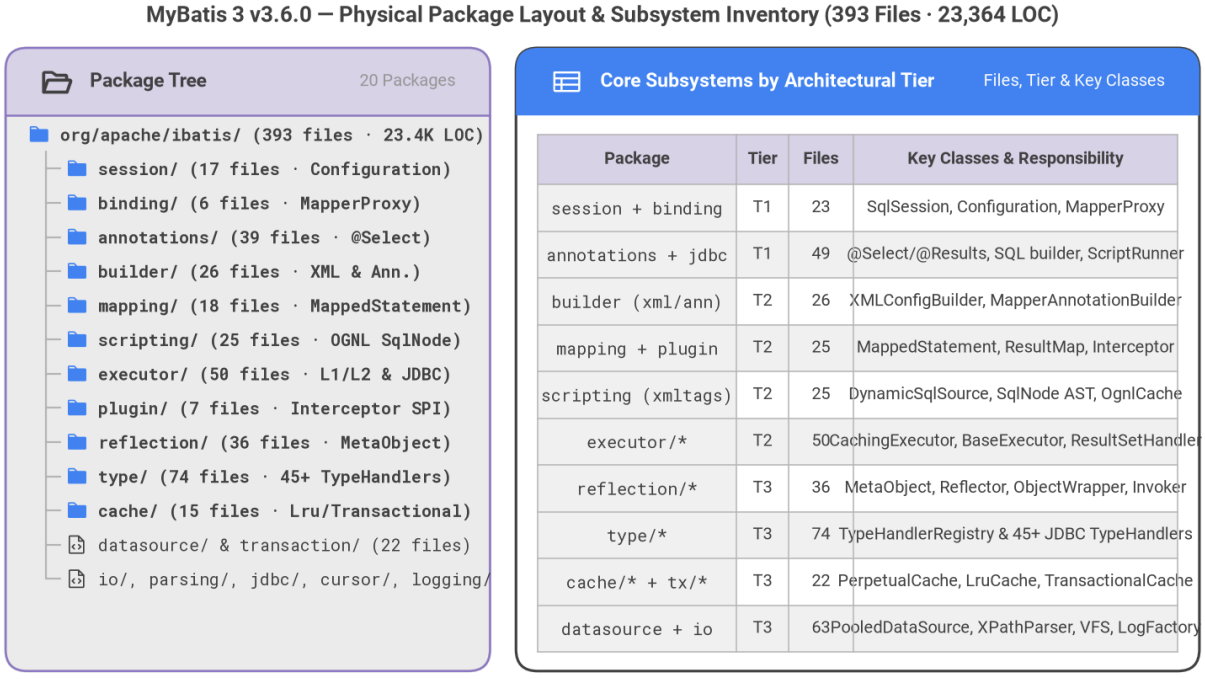
Summary of 7-Dimension Scores & Rationales

Dimension	Score	Grade	Key Quantitative Evidence & Architectural Rationale
Testing	**95 / 100**	**S**	`372` JUnit 5 test files (`1,918` AST methods, `2,009` runtime executions); `1,990` passed, `0` failed, `0` errors offline (`--network=none`) in `108.88s` ; `87.4%` line (`9,985/11,418`) and `82.7%` branch coverage via JaCoCo `0.8.15` .
Typing	**94 / 100**	**S**	`99.9%` generic type safety coverage across `2,721` methods; only `2` raw generic signatures (`LruCache.java:53` , `OgnlClassResolver.java:32`); `248` `Object` / `@SuppressWarnings("unchecked")` usages confined to reflection/proxy boundaries.
Dependencies	**93 / 100**	**S**	`9` pinned optional/provided dependencies in `pom.xml` ; `maven-shade-plugin` relocates `ognl:3.4.16` and `javassist:3.33.0-GA` into `org.apache.ibatis.*` ; reproducible `mvnw` , `dependencies-lock.json` , and `project.build.outputTimestamp` .
Security	**91 / 100**	**S**	`0` Trivy CVEs (`CRITICAL=0` , `HIGH=0` , `MEDIUM=0` , `LOW=0`), `0` secrets, `0` IaC misconfigs; hardened `XPathParser` (`FEATURE_SECURE_PROCESSING=true`); `SerialFilterChecker.check()` warns on missing JEP-290 `jdk.serialFilter` (`CWE-502`).

Dimension	Score	Grade	Key Quantitative Evidence & Architectural Rationale
Architecture	**86 / 100**	**A**	Cohesive 3-tier layout across `20` packages under `org.apache.ibatis.*` using Decorator, Template Method, Composite, and Dynamic Proxy patterns; `22` class-level cycles (`4` cross-package via `@Arg -> UnknownTypeHandler -> Configuration`).
Code Quality	**85 / 100**	**A**	`100.0%` import hygiene (`0` wildcard imports across `393` files); `59` complex methods led by `DefaultParameterHandler.setParameters` (`cognitive=129`) and `PooledDataSource.popConnection` (`cognitive=78`), plus `17` methods with `>6` parameters.
Documentation	**85 / 100**	**A**	`20/20` `package-info.java` descriptors, structured `src/site/` documentation, and `README.md` , offset by `16.3%` inline public Javadoc coverage and `24` `@param` tag mismatches in `AbstractSQL.java` and `ResolverUtil.java` .

2. Architecture & Source Code Structure

MyBatis 3 (`v3.6.0`) organizes **393 Java source files** (**23,364 LOC**, **374 classes**, **2,721 methods**) across **20 packages** under `org.apache.ibatis.*` into a **3-Tier Layered Data-Mapper & Interceptor Pipeline Architecture** (**86/100**, Grade **A**). Rather than imposing an invasive entity state manager like full JPA/Hibernate ORMs, MyBatis compiles XML descriptors (`mybatis-config.xml` , `*Mapper.xml`) and Java interface annotations (`@Select` , `@Insert` , `@Results`) at bootstrap time into immutable `MappedStatement` and `ResultMap` registries inside `Configuration` , and executes SQL through a composable `Executor -> StatementHandler -> ParameterHandler -> ResultSetHandler` pipeline.

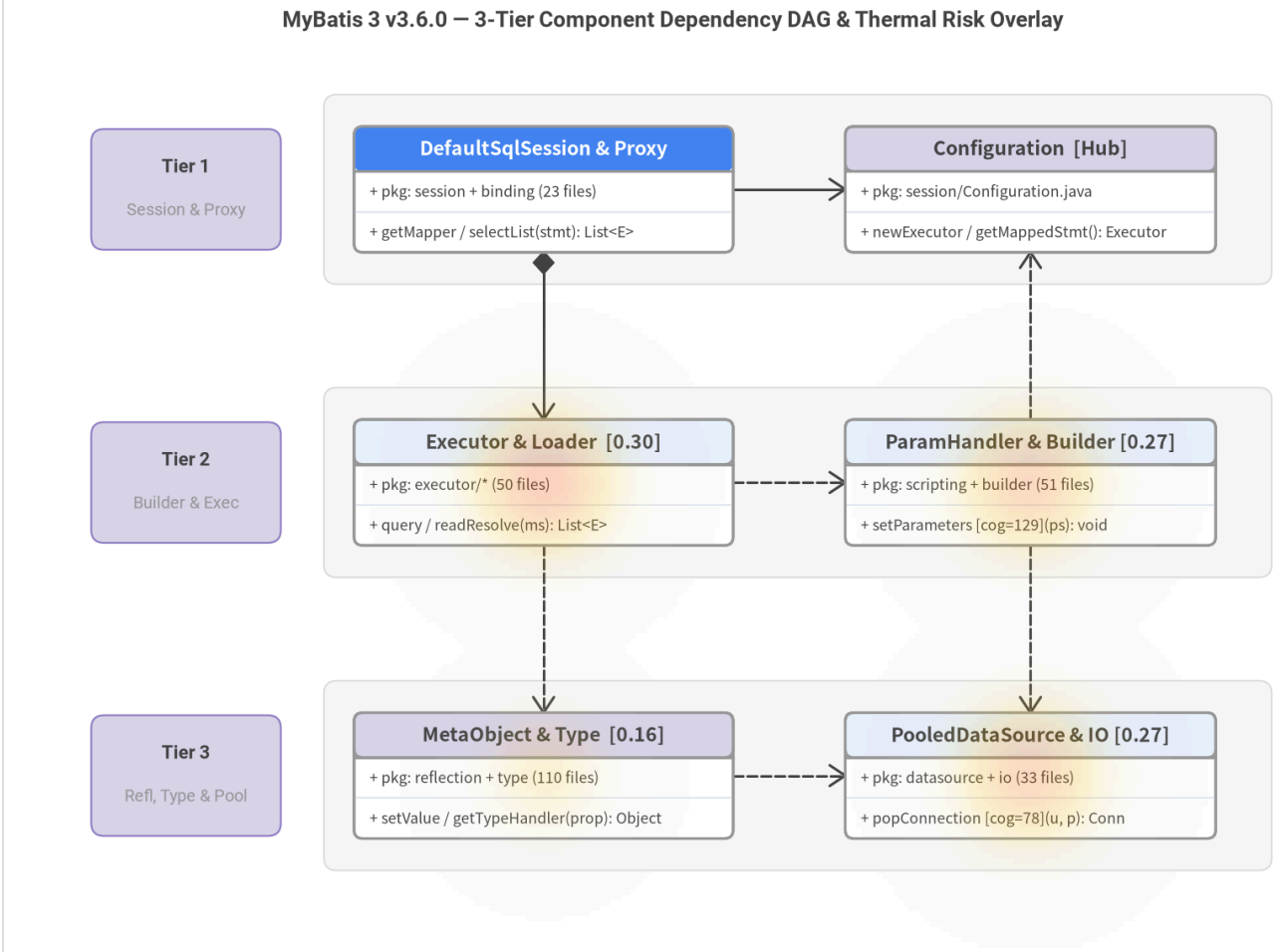


MyBatis 3 v3.6.0 Source Package Tree & 20-Package Subsystem Inventory (393 Files, 23,364 LOC)

2.1 3-Tier Package Topology & Thermal Risk Heatmap Overlay

MyBatis 3's 20 packages stratify into three architectural tiers:

- **Tier 1 — Public Session, Annotation & Dynamic Proxy Binding Layer** (`session` , `binding` , `annotations` , `cursor` , `jdbc`): Exposes `SqlSessionFactoryBuilder` , `SqlSessionFactory` , `SqlSession` , `MapperRegistry` , and `MapperProxyFactory<T>` .
- **Tier 2 — Core Configuration Builder, Mapping, Scripting & Executor Layer** (`builder` , `mapping` , `scripting` , `executor` , `plugin`): Compiles XML and annotation mappers into `MappedStatement` / `ResultMap` instances, evaluates OGNL `SqlNode` trees into `BoundSql` , and orchestrates L1/L2 cached JDBC execution wrapped by `Plugin.wrap()` interceptor chains.
- **Tier 3 — Foundation Reflection, Type, Cache, Transaction & IO Layer** (`reflection` , `type` , `cache` , `transaction` , `datasource` , `parsing` , `io` , `logging` , `exceptions`): Provides self-contained infrastructure (`MetaObject` , `Reflector` , `TypeHandlerRegistry` , `PerpetualCache` decorators, `PooledDataSource` , `XPathParser` , `VFS` , `LogFactory`).



MyBatis 3 v3.6.0 — 3-Tier Component Dependency Graph with Thermal Risk Overlay (Hotspots: CglibProxyFactory=0.30, DefaultParameterHandler=0.27, PooledDataSource=0.27)

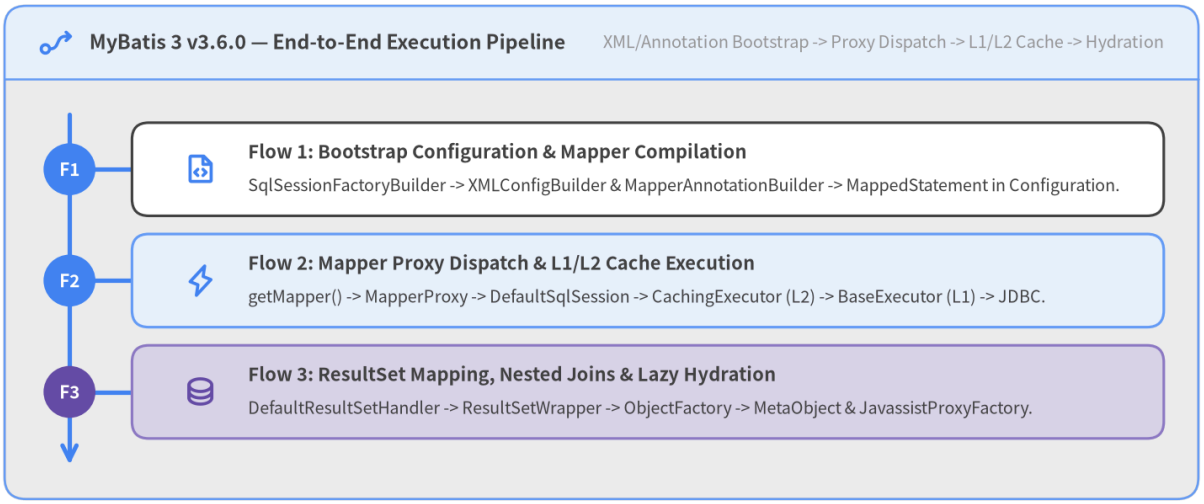
Pre-Sorted Module Hotspots (`HeatmapOverlay` Exact Risk Scores)

Module Path	LOC	Risk Score	Findings	Triggered Rules & Primary Risk Driver
`src/main/java/org/apache/ibatis/executor/loader/cglib/CglibProxyFactory.java`	`174`	`0.30`	`1` (`info`)	`common/runtime_verification` — Deprecated legacy CGLIB proxy factory (`0.0%` coverage on JDK 21 due to `RequireIllegalAccess` exclusion)
`src/main/java/org/apache/ibatis/datasource/pooled/PooledDataSource.java`	`445`	`0.27`	`1` (`medium`)	`common/maintainability` — `popConnection` has cognitive complexity `78` (`117` lines, `21` branches)
`src/main/java/org/apache/ibatis/scripting/defaults/DefaultParameterHandler.java`	`171`	`0.27`	`1` (`medium`)	`common/maintainability` — `setParameters` has cognitive complexity `129` (`93` lines, `22` branches)

Module Path	LOC	Risk Score	Findings	Triggered Rules & Primary Risk Driver
`src/main/java/org/apache/ibatis/executor/loader/AbstractSerialStateHolder.java`	`94`	`0.27`	`1` (`medium`)	`common/security_vulnerability` — `ObjectInputStream` deserialization (`CWE-502`) guarded by warn-only `SerialFilterChecker.check()`
`src/main/java/org/apache/ibatis/io/SerialFilterChecker.java`	`30`	`0.20`	`1` (`low`)	`common/security_vulnerability` — Logs one-time warning when JEP-290 `jdk.serialFilter` is unset; static `firstInvocation` flag
`src/main/java/org/apache/ibatis/logging/log4j2/Log4j2LoggerImpl.java`	`41`	`0.16`	`0`	Fallback non- `LocationAware` Log4j2 logger implementation (`0.0%` default test coverage)
`src/main/java/org/apache/ibatis/reflection/Jdk.java`	`39`	`0.16`	`0`	Legacy deprecated JDK capability flags (`0.0%` coverage)
`src/main/java/org/apache/ibatis/logging/slf4j/Slf4jLoggerImpl.java`	`37`	`0.16`	`0`	Fallback non- `LocationAwareLogger` SLF4J wrapper (`0.0%` default test coverage)

2.2 End-to-End Runtime Execution Flows & Concurrency Model

MyBatis 3 separates its runtime into three primary execution flows: (1) **Bootstrap Compilation** (`SqlSessionFactoryBuilder` -> `XMLConfigBuilder` / `MapperAnnotationBuilder` -> `Configuration`), (2) **Mapper Proxy & L1/L2 Cache Query Execution** (`MapperProxy` -> `MapperMethod` -> `DefaultSqlSession` -> `CachingExecutor` -> `BaseExecutor` -> `PreparedStatementHandler`), and (3) **ResultSet Hydration & Lazy Proxy Loading** (`DefaultResultSetHandler` -> `MetaObject` / `Reflector` / `JavassistProxyFactory`).



MyBatis 3 v3.6.0 — 3 Core End-to-End Execution Flows (Bootstrap Compilation, L1/L2 Cached Query Pipeline, and ResultSet Hydration)

State Management, Error Translation & Thread-Safety Contract

Runtime Mechanism	Scope & Concurrency Contract	Key Implementation Classes
`Configuration` **Registry**	**Application-scoped (Thread-Safe after bootstrap)**: Stores `StrictMap` and `ConcurrentHashMap` registries of `MappedStatement`, `ResultMap`, `Cache`, `TypeHandler`, and `MapperProxyFactory`.	`Configuration`, `MapperRegistry`, `DefaultReflectorFactory`, `OgnlCache`
L2 Namespace Cache	**Application/Namespace-scoped (Transactional)**: Buffers reads/writes per session inside `TransactionalCache` (`TransactionalCacheManager`) and flushes to `LruCache` / `SerializedCache` / `SynchronizedCache` only upon `SqlSession.commit()`.	`CachingExecutor`, `TransactionalCacheManager`, `TransactionalCache`, `CacheBuilder`
L1 Local Cache	**Request/** `SqlSession` **-scoped (Single-Thread Confined)**: `PerpetualCache` inside `BaseExecutor` (`SESSION` or `STATEMENT` scope), automatically cleared on any `insert` / `update` / `delete` / `commit` / `rollback`.	`BaseExecutor`, `PerpetualCache`, `LocalCacheScope`
`ErrorContext` **& Exceptions**	**ThreadLocal Breadcrumbs**: `ErrorContext.instance()` records the active XML resource, `MappedStatement` ID, SQL string, and cause before `ExceptionFactory.wrapException()` translates checked `SQLException`s into unchecked `PersistenceException` subclasses.	`ErrorContext`, `ExceptionFactory`, `PersistenceException`

3. Recommended Remediation Roadmap

MyBatis 3 `v3.6.0` enters remediation planning from a strong **90/100 (Grade S)** baseline with **zero `P0` urgent blockers**, **zero `FAIL` compliance rules**, and **zero `CRITICAL` or `HIGH` source-code findings** across all 393 Java source files and 1,990 passing offline tests. The 8-item engineering roadmap prioritizes **2 `P1` high-value maintainability and deserialization hardening enhancements** followed by **6 `P2` architectural, documentation, modernization, supply-chain, and test-suite polish actions**.

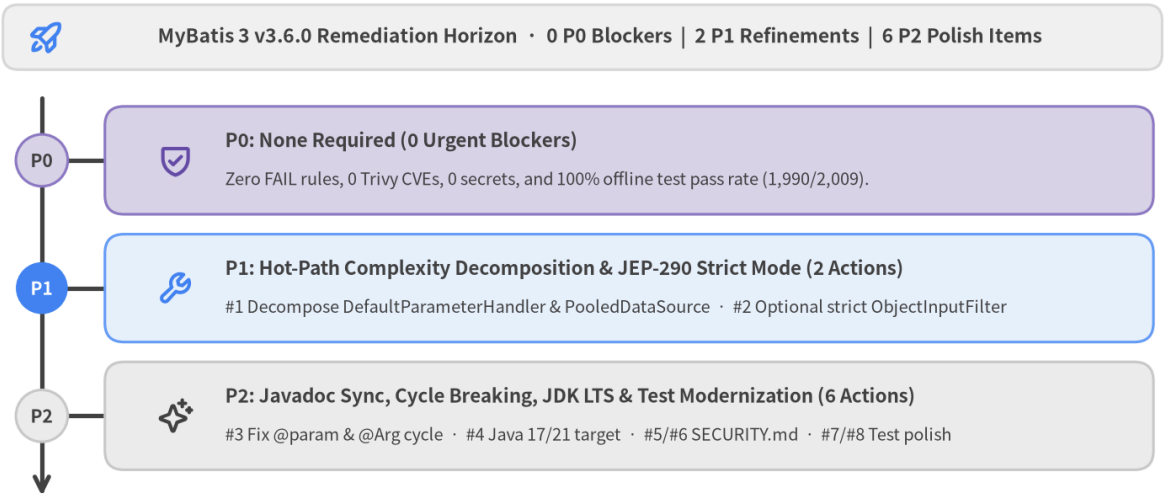


Figure 3.1 — Phased Engineering Refinement Roadmap for MyBatis 3 v3.6.0 (0 P0 Urgent Blockers · 2 P1 High-Leverage · 6 P2 Polish)

3.1 Action Plan Traceability Matrix (`P0 -> P1 -> P2`)

Every remediation item maps directly to existing repository files, expected engineering outcomes, and triggered rule IDs or CWE identifiers (`1..8` pre-sorted by priority):

Remediation Action Plan Traceability Matrix (0 P0 Urgent · 2 P1 High-Leverage · 6 P2 Polish)

Priority	Action Title	Target Files	Expected Impact	Related Rules
[P1] #1 maintainability	Decompose high-complexity hot paths in DefaultParameterHandler and PooledDataSource	DefaultParameterHandler.java PooledDataSource.java MapperAnnotationBuilder.java	Brings cognitive complexity below 25 and improves unit testability of hot paths	common/ maintainability
[P1] #2 security	Add Optional Strict Per-Stream ObjectInputFilter Enforcement for Deserialization	AbstractSerialStateHolder.java SerialFilterChecker.java SerializedCache.java	Eliminates CWE-502 exposure when global jdk.serialFilter is omitted at JVM startup	common/ security_vulnerability SEC-04 / CWE-502
[P2] #3 code_quality	Fix Javadoc @param mismatches and break @Arg -> UnknownTypeHandler cycle	AbstractSQL.java ResolverUtil.java MapperBuilderAssistant.java Arg.java	Eliminates 24 Javadoc tag mismatches and removes 4 cross-package cycles	java/code_quality common/architecture
[P2] #4 modernization	Plan baseline JDK target migration from Java 11 to Java 17/21 LTS	pom.xml	Enables native Java records, pattern matching, and modern bytecode optimizations	java/dependencies
[P2] #5 security	Publish SECURITY.md Emphasizing #{} Parameter Binding and JEP-290 Serial Filters	pom.xml README.md	Guides users on safe #{} binding vs ${} interpolation and JEP-290 whitelists	common/supply_chain SEC-01
[P2] #6 supply_chain	Add SECURITY.md disclosure policy and dependency update config	README.md pom.xml	Improves OpenSSF Scorecard supply-chain governance and automated CVE tracking	common/supply_chain
[P2] #7 testing	Add unit tests for non-LocationAware logger wrapper fallbacks	Slf4jLoggerImpl.java Log4j2LoggerImpl.java	Eliminates 0% coverage gaps in fallback SLF4J and Log4j2 logger adapters	common/ runtime_verification
[P2] #8 testing	Migrate remaining catch-exception tests to AssertJ assertThatThrownBy	BindingTest.java pom.xml	Retires legacy catch-exception agent dependency across 126 exception test methods	java/testing

Figure 3.2 — Action Plan Traceability Matrix Mapping Priorities, Target Files, Expected Impact, and Audit Rules

---

Detailed Remediation Specifications (`1..8`)

1. `[P1]` **Decompose high-complexity hot paths in** `DefaultParameterHandler` **and** `PooledDataSource` (`maintainability`):
   - **Targets**: `src/main/java/org/apache/ibatis/scripting/defaults/DefaultParameterHandler.java` , `src/main/java/org/apache/ibatis/datasource/pooled/PooledDataSource.java` , `src/main/java/org/apache/ibatis/builder/annotation/MapperAnnotationBuilder.java`
   - **Related Rules**: `common/maintainability`
   - **Action**: Extract focused private helper methods in `DefaultParameterHandler.setParameters` (`cognitive=129`),

`PooledDataSource.popConnection` (`cognitive=78`), and `MapperAnnotationBuilder.getReturnType` (`cognitive=68`) to bring per-method cognitive complexity below `25`.

- **Expected Impact**: Improves readability, unit testability, and maintainability of parameter binding and connection pooling hot paths.

2. `[P1]` **Add Optional Strict Per-Stream `ObjectInputFilter` Enforcement for Deserialization (`security`)**:
   - **Targets**: `src/main/java/org/apache/ibatis/executor/loader/AbstractSerialStateHolder.java`, `src/main/java/org/apache/ibatis/io/SerialFilterChecker.java`, `src/main/java/org/apache/ibatis/cache/decorators/SerializedCache.java`
   - **Related Rules**: `common/security_vulnerability`, `SEC-04`, `CWE-502`
   - **Action**: Support configuring a custom `ObjectInputFilter` (Java 9+) or fail-closed strict mode in `SerialFilterChecker` so applications using `SerializedCache` or lazy-loader serialization are protected even when the global JVM `jdk.serialFilter` property is omitted.
   - **Expected Impact**: Eliminates `CWE-502` unsafe deserialization exposure when L2 cache or lazy state payloads are stored in external or shared media.
3. `[P2]` **Fix Javadoc `@param` mismatches and break `@Arg -> UnknownTypeHandler` cycle (`code_quality`)**:
   - **Targets**: `src/main/java/org/apache/ibatis/jdbc/AbstractSQL.java`, `src/main/java/org/apache/ibatis/io/ResolverUtil.java`, `src/main/java/org/apache/ibatis/builder/MapperBuilderAssistant.java`, `src/main/java/org/apache/ibatis/annotations/Arg.java`
   - **Related Rules**: `java/code_quality`, `common/architecture`
   - **Action**: Synchronize the `24` mismatched Javadoc `@param` tags in `AbstractSQL`, `ResolverUtil`, and `MapperBuilderAssistant`, and decouple `@Arg` / `@Case` from concrete `UnknownTypeHandler -> Configuration` dependencies.
   - **Expected Impact**: Eliminates Javadoc compiler warnings and removes the 4 cross-package dependency cycles.
4. `[P2]` **Plan baseline JDK target migration from Java 11 to Java 17/21 LTS (`modernization`)**:

- **Targets**: `pom.xml`
- **Related Rules**: `java/dependencies`
- **Action**: Update `<java.version>` and `<java.release.version>` in `pom.xml` (lines 67–68) to `17` or `21` LTS on the next major release line and consolidate legacy JDK activation profiles.
- **Expected Impact**: Enables native Java records, pattern matching, and modern bytecode optimizations without multi-profile workarounds.

5. `[P2]` **Publish** `SECURITY.md` **Emphasizing** `#{}` **Parameter Binding and JEP-290 Serial Filters (** `security` **)**:
   - **Targets**: `pom.xml`, `README.md`
   - **Related Rules**: `common/supply_chain`, `SEC-01`
   - **Action**: Add a `SECURITY.md` policy detailing upstream security reporting channels, mandatory JEP-290 `jdk.serialFilter` patterns for `SerializedCache`, and safe `#{}` `PreparedStatement` parameter binding versus `${}` OGNL string interpolation.
   - **Expected Impact**: Improves OpenSSF Scorecard supply-chain governance and helps downstream developers prevent SQL injection and deserialization misconfigurations.
6. `[P2]` **Add** `SECURITY.md` **disclosure policy and dependency update config (** `supply_chain` **)**:
   - **Targets**: `README.md`, `pom.xml`
   - **Related Rules**: `common/supply_chain`
   - **Action**: Add a `SECURITY.md` file detailing upstream MyBatis security reporting procedures and commit `renovate.json` for automated dependency monitoring.
   - **Expected Impact**: Improves OpenSSF Scorecard supply-chain governance posture.
7. `[P2]` **Add unit tests for non-** `LocationAware` **logger wrapper fallbacks (** `testing` **)**:
   - **Targets**: `src/main/java/org/apache/ibatis/logging/slf4j/Slf4jLoggerImpl.java`, `src/main/java/org/apache/ibatis/logging/log4j2/Log4j2LoggerImpl.java`
   - **Related Rules**: `common/runtime_verification`
   - **Action**: Add unit tests in `src/test/java/org/apache/ibatis/logging/` exercising `Slf4jLoggerImpl` and `Log4j2LoggerImpl` directly with mock `Logger` instances.
   - **Expected Impact**: Eliminates `0%` coverage gaps in fallback logging adapters.

8. `[P2]` **Migrate remaining `catch-exception` tests to AssertJ `assertThatThrownBy` or JUnit 5 `assertThrows` (`testing`):**

   - **Targets**: `src/test/java/org/apache/ibatis/binding/BindingTest.java`, `pom.xml`
   - **Related Rules**: `java/testing`
   - **Action**: Replace `BDDCatchException.when(...)/then(caughtException())` calls in `126` test methods with AssertJ `assertThatThrownBy(...)` and remove `com.github.hazendaz.catch-exception` from `pom.xml`.
   - **Expected Impact**: Simplifies the test dependency graph and eliminates bytecode agent overhead for exception assertions.

4. Audit Standards, Rule Compliance & Findings

PNI501 evaluated MyBatis 3 `v3.6.0` against **15 active engineering rules** across **6 audit steps**, recording **0** `FAIL`, **6** `WARN`, **8** `PASS`, and **1** `NOT_APPLICABLE` (`java/frameworks/spring_boot`). All 13 raw observations consolidate deterministically into **12 unique** `file:line` **locations** (`0 CRITICAL`, `0 HIGH`, `3 MEDIUM`, `8 LOW`, `1 INFO`).

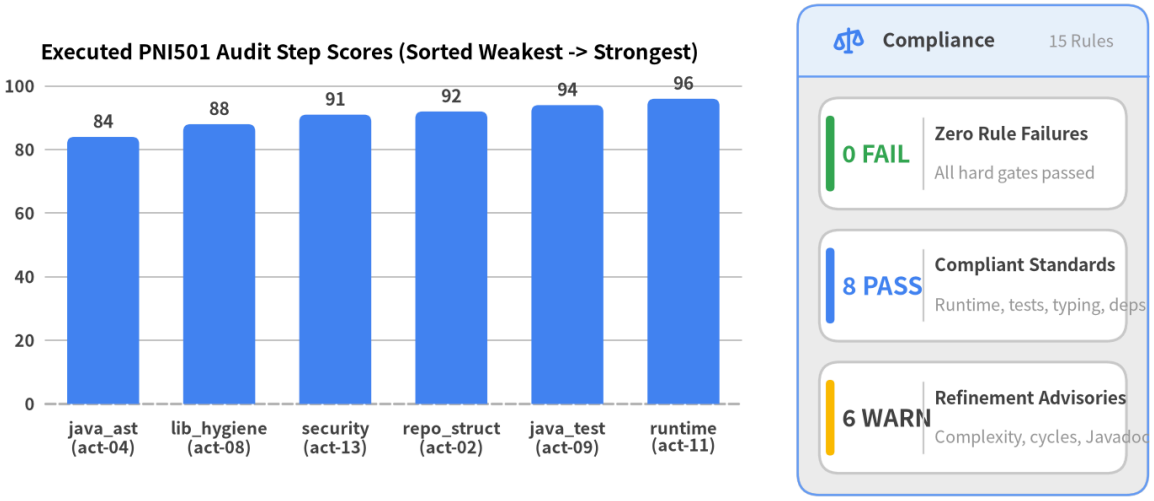


Figure 4.1 — Executed Audit Step Scores (Weakest-First) & Rule Compliance Distribution

4.1 Executed Audit Step Score Breakdown

Audit Step ID	Action	Score	Grade	Rule Verdicts	Synthesis & Primary Observations
`java_ast_audit`	`act-04`	**84 / 100**	**A**	`3 PASS`, `3 WARN`, `0 FAIL`	`100.0%` import hygiene (`0` wildcard imports across `393` files / `23,364` LOC) and `99.9%` generic type coverage; `59` complex methods (`DefaultParameterHandler.setParameters=129`), `17` methods with `>6` params, `22` class cycles, and `16.3%` Javadoc coverage.

Audit Step ID	Action	Score	Grade	Rule Verdicts	Synthesis & Primary Observations
`library_hygiene_audit`	`act-08`	**88 / 100**	**A**	`1 PASS`, `2 WARN`, `0 FAIL`	Declares `Automatic-Module-Name: org.mybatis` and OSGi exports (`pom.xml:86-91`), ships `20/20` `package-info.java` , shades OGNL & Javassist, makes all 9 dependencies `<optional>true</optional>` , and has `0` `System.exit()` calls.
`security_vulnerability_audit`	`act-13`	**91 / 100**	**S**	`0 PASS`, `2 WARN`, `0 FAIL`	Trivy `0.69.3` verified `0` CVEs across `pom.xml` and `dependencies-lock.json` , `0` misconfigurations, and `0` secrets; `XPathParser` disables entity expansion; `AbstractSerialStateHolder.java:110` (`CWE-502`) calls warn-only `SerialFilterChecker.check()` .
`repo_structure_audit`	`act-02`	**92 / 100**	**S**	`4 PASS`, `1 WARN`, `0 FAIL`	Exact version pinning in `pom.xml` , committed `mvnw` and `dependencies-lock.json` , deterministic `project.build.outputTimestamp` , and clean Apache-2.0 licensing (`LICENSE` + `LICENSE-MYBATIS`).
`java_test_audit`	`act-09`	**94 / 100**	**S**	`1 PASS`, `0 WARN`, `0 FAIL`	`372` JUnit 5 test files (`1,918` methods, `81.5%` module mirror coverage) plus `src/test/java/org/apache/ibatis/submitted/` regression suite; hermetic HSQLDB/Derby/H2 databases via `BaseDataTest` .
`container_runtime_audit`	`act-11`	**96 / 100**	**S**	`2 PASS`, `0 WARN`, `0 FAIL`	All 4 stages passed in `maven:3.9-eclipse-temurin-21` under `--network=none` : `1,990` passed, `0` failed, `0` errors (`19` skipped) in `108.88s` with `87.4%` line (`9,985/11,418`) and `82.7%` branch coverage via JaCoCo `0.8.15` .

4.2 Full Rule Compliance Matrix (`FAIL -> WARN -> PASS`)

Status	Rule ID	Source Step	Deterministic Evidence & Compliance Rationale
`[WARN]`	`common/architecture`	`java_ast_audit`	`22` class-level circular dependencies: `4` cross-package cycles through `Configuration -> MapperRegistry -> MapperAnnotationBuilder -> @Arg/@Case -> UnknownTypeHandler -> Configuration` , plus `18` intra-package cycles (`PooledDataSource <-> PoolState <-> PooledConnection` , `MetaObject <-> SystemMetaObject` , `Reflector <-> Invoker` , `VFS <-> DefaultVFS/JBoss6VFS`).
`[WARN]`	`common/documentation`	`library_hygiene_audit`	`README.md` (`5` sections), `src/site/` multilingual XDoc/Markdown documentation, and `20/20` `package-info.java` files; inline `docstring_coverage_pct=16.3%` and `doc_signature_mismatches=24` (`AbstractSQL.java:62-175` , `ResolverUtil.java:197,221` , `MapperBuilderAssistant.java:277`).

Status	Rule ID	Source Step	Deterministic Evidence & Compliance Rationale
[WARN]	common/maintainability	java_ast_audit	59 complex functions led by DefaultParameterHandler.java:89 (cognitive=129, 93 lines), PooledDataSource.java:435 (cognitive=78, 117 lines), CacheBuilder.java:142 (cognitive=69), and MapperAnnotationBuilder.java:444 (cognitive=68); 17 methods with >6 parameters in MapperBuilderAssistant.java:203,277,287 (up to 22 params).
[WARN]	common/security_vulnerability	act-13	Trivy 0.69.3 filesystem scan passed with 0 application CVEs, 0 OS CVEs, 0 misconfigurations, and 0 secrets. XPathParser.java:233-240 sets FEATURE_SECURE_PROCESSING=true and expandEntityReferences=false. One CWE-502 ObjectInputStream sink at AbstractSerialStateHolder.java:110 calls SerialFilterChecker.check() (line 107), which warns when JEP-290 jdk.serialFilter is unset.
[WARN]	common/supply_chain	repo_structure_audit	Committed dependencies-lock.json and mvnw; 0 unpinned dependencies; LICENSE and LICENSE-MYBATIS present; .pni/dockerfiles/root/Dockerfile pins maven:3.9-eclipse-temurin-21 and runs as non-root USER pni; SECURITY.md=False and dependency_automation=False in snapshot repository.
[WARN]	java/code_quality	java_ast_audit	import_hygiene_coverage_pct=100.0% (0 wildcard imports); docstring_coverage_pct=16.3% (1,050 missing, 233 stub Javadocs, 24 @param mismatches); 9 mutable static fields in JBoss6VFS.java:39-85, Resources.java:43, SerialFilterChecker.java:28, and LogFactory.java:33.
[PASS]	common/git_workflow	repo_structure_audit	.gitignore (244 lines covering Python, Java/Maven target/, Derby logs, .drawlib/, and .pni/cache/); clean trunk history with 0 conflict markers.
[PASS]	common/library_guidelines	library_hygiene_audit	pom.xml:86-91 (Automatic-Module-Name: org.mybatis, osgi.export), pom.xml:115-134,287-310 (<optional>true</optional>), pom.xml:365-411 (maven-shade-plugin relocation), 0 System.exit calls, typed PersistenceException hierarchy, and LogFactory.java pluggable SPI.
[PASS]	common/production_readiness	container_runtime_audit	Thread-safe Configuration / DefaultReflectorFactory / OgnlCache registries, bounded PooledDataSource connection checkout/ping lifecycle, configurable Statement.setQueryTimeout propagation in BaseStatementHandler, and structured SLF4J/Log4j2 logging adapters.
[PASS]	common/runtime_verification	container_runtime_audit	RuntimeFacts.status='passed'; harness_build.status='passed'; test_execution.status='passed' (2,009 total, 1,990 passed, 0 failed, 0 errors, 19 skipped in 108.88s with --network=none); line_coverage_pct=87.4%, branch_coverage_pct=82.7% (9,985/11,418 statements via JaCoCo 0.8.15); smoke_check.status='passed'.
[PASS]	common/security	repo_structure_audit	committed_secret_files=[] across 393 source and 372 test files; hardcoded_secrets=0; StdOutImpl.java:41-62 is an explicit opt-in stdout logger adapter; DefaultVFS.java:67-341 and Resources.java:273 open local classpath JAR/file URLs rather than external network sockets.
[PASS]	java/dependencies	repo_structure_audit	pom.xml:67-325,365-411, mvnw, dependencies-lock.json (0 unpinned dependencies; strict <optional>true</optional> and <scope>test</scope> separation; shaded ognl / javassist relocation to org.apache.ibatis.*).

Status	Rule ID	Source Step	Deterministic Evidence & Compliance Rationale
`[PASS]`	`java/testing`	`java_test_audit`	`372` test files vs `393` source files; `1,918` JUnit Jupiter `@Test` / `@ParameterizedTest` methods; `81.5%` package mirror coverage across all `20` packages plus `src/test/java/org/apache/ibatis/submitted/` regression suite; `BaseDataTest.java` hermetic HSQLDB/Derby/H2 seeding.
`[PASS]`	`java/typing`	`java_ast_audit`	`type_safety_coverage_pct=99.9%` across `393` files (`2,721` functions); `LruCache.java:54` uses `Map.Entry<Object, Object>`; `OgnlClassResolver.java:32` overrides OGNL `ClassResolver` raw signature; `248` `Object` / `@SuppressWarnings` usages confined to reflective boundaries.
`[N/A]`	`java/frameworks/spring_boot`	`java_ast_audit`	`ProjectFacts.runtime_types=['library']`, `frameworks=['junit5']`; standalone `org.mybatis:mybatis` SQL mapper library with zero Spring dependencies (Spring integration lives in separate `mybatis-spring` repository).

4.3 Consolidated Location Findings Index (`CRITICAL -> INFO`)

Deduplicating the 13 raw observations by `file:line` produces **12 unique finding locations** (`0 CRITICAL`, `0 HIGH`, `3 MEDIUM`, `8 LOW`, `1 INFO`):

Consolidated Location Findings Matrix (12 Unique file:line Coordinates · 3 MEDIUM · 8 LOW · 1 INFO)

Severity	Location (file:line)	Rule ID	Diagnostic Evidence	Recommended Fix
[MEDIUM] #1	PooledDataSource.java:435	common/ maintainability	popConnection: 117 LOC, 21 branches, cognitive=78	Split idle checkout, overdue eviction & ping validation
[MEDIUM] #2	AbstractSerialState-Holder.java:110	common/ security_vulnerability	ObjectInputStream (CWE-502) with warn-only JEP-290 check	Allow per-stream ObjectInput-Filter or strict fail-closed
[MEDIUM] #3	DefaultParameter-Handler.java:89	common/ maintainability	setParameters: 93 LOC, 22 branches, cognitive=129	Extract value, ParamMap type & TypeHandler helper methods
[LOW] #4	README.md:1	common/supply_chain	SECURITY.md=False, dependency_automation=False	Add SECURITY.md & renovate.json in repository root
[LOW] #5	pom.xml:1	common/supply_chain	dependencies-lock.json present; SECURITY.md omitted	Publish SECURITY.md covering #{} vs ${} & JEP-290 filters
[LOW] #6	pom.xml:67	java/dependencies	<java.version>11</java.version> baseline bytecode target	Advance baseline to Java 17/21 LTS in next major release
[LOW] #7	Arg.java:25	common/architecture	Cycle: Arg -> UnknownTypeHandler -> Configuration -> Arg	Decouple @Arg/@Case default from UnknownTypeHandler
[LOW] #8	MapperBuilder-Assistant.java:203	common/ maintainability	addMappedStatement: 22, 20, and 19 positional params	Pass MappedStatement.Builder or descriptor object
[LOW] #9	SerialFilter-Checker.java:43	common/ security_vulnerability	One-time log.warn when jdk.serialFilter is missing	Add strictSerialFilter option to fail closed when unset
[LOW] #10	AbstractSQL.java:62	common/documentation java/code_quality	24 Javadoc @param mismatches; 16.3% overall Javadoc cov.	Sync @param tags in AbstractSQL, ResolverUtil & Assistant
[LOW] #11	BindingTest.java:151	java/testing	126 tests use BDDCatchException instead of AssertJ/JUnit 5	Migrate to assertThatThrownBy and retire catch-exception
[INFO] #12	CglibProxyFactory.java:55	common/ runtime_verification	0.0% JaCoCo coverage on JDK 21 (RequireIllegalAccess skipped)	Retire deprecated CGLIB proxy or test fallback loggers

Figure 4.2 — Consolidated Location Findings Matrix (12 Unique Locations: 0 CRITICAL · 0 HIGH · 3 MEDIUM · 8 LOW · 1 INFO)

Complete Consolidated Findings Reference (`1..12`)

1. `[MEDIUM]` `src/main/java/org/apache/ibatis/datasource/pooled/PooledDataSource.java:435` (`common/maintainability`):
   - **Evidence**: `length=117 lines, branches=21, cognitive=78`
   - **Recommendation**: Decompose `popConnection` into smaller private methods handling idle connection retrieval, overdue active connection reclamation, and connection validation.
2. `[MEDIUM]` `src/main/java/org/apache/ibatis/executor/loader/AbstractSerialStateHolder.java:110` (`common/security_vulnerability`):

- **Evidence**: `SerialFilterChecker.check(); try (ObjectInputStream in = new ObjectInputStream(new ByteArrayInputStream(this.userBeanBytes))) { this.userBean = in.readObject(); ... }`
- **Recommendation**: Allow configuring a dedicated `ObjectInputFilter` on `Configuration` (or enforce a default package allowlist on the `ObjectInputStream` instance via `in.setObjectInputFilter(...)`) when `jdk.serialFilter` is not set at the JVM level.

3. `[MEDIUM]` `src/main/java/org/apache/ibatis/scripting/defaults/DefaultParameterHandler.java:89` (`common/maintainability`):
   - **Evidence**: `length=93 lines, branches=22, cognitive=129`
   - **Recommendation**: Extract helper methods for parameter value resolution (`resolveParameterValue`), `ParamMap` generic type inference (`resolveParamMapGenericType`), and `TypeHandler` selection (`resolveTypeHandler`).
4. `[LOW]` `README.md:1` (`common/supply_chain`):
   - **Evidence**: `ProjectFacts.has_security_policy=False, has_dependency_automation=False`
   - **Recommendation**: Add a root `SECURITY.md` documenting vulnerability reporting channels and include `renovate.json` for automated dependency tracking.
5. `[LOW]` `pom.xml:1` (`common/supply_chain`):
   - **Evidence**: `ProjectFacts: LICENSE=True, dependencies-lock.json present, SECURITY.md=False, dependency_automation=False`
   - **Recommendation**: Add a `SECURITY.md` documenting the vulnerability disclosure process and JEP-290/SQL-injection security guidance (e.g., `#{}` `PreparedStatement` binding vs `${}` string substitution), and configure Dependabot for Maven dependencies.
6. `[LOW]` `pom.xml:67` (`java/dependencies`):
   - **Evidence**: `<java.version>11</java.version> / <java.release.version>11</java.release.version>`
   - **Recommendation**: Consider advancing the baseline bytecode target to Java 17 or Java 21 LTS in future major releases to leverage modern JVM intrinsics, records, and sealed types natively.

7. `[LOW]` `src/main/java/org/apache/ibatis/annotations/Arg.java:25` (`common/architecture`):
   - **Evidence**: `Circular dependency: Arg -> UnknownTypeHandler -> Configuration -> MapperRegistry -> MapperAnnotationBuilder -> Arg`
   - **Recommendation**: Decouple annotation defaults by referencing the `TypeHandler.class` interface as the default sentinel or breaking `UnknownTypeHandler`'s direct dependency on `Configuration`.
8. `[LOW]` `src/main/java/org/apache/ibatis/builder/MapperBuilderAssistant.java:203` (`common/maintainability`):
   - **Evidence**: `params=22 (> 6, SIG Unit Interfacing); overloaded at lines 277 (20 params) and 287 (19 params)`
   - **Recommendation**: Prefer passing `MappedStatement.Builder` or a dedicated `StatementDescriptor` parameter object.
9. `[LOW]` `src/main/java/org/apache/ibatis/io/SerialFilterChecker.java:43` (`common/security_vulnerability`):
   - **Evidence**: `if (firstInvocation && SERIAL_FILTER_MISSING) { firstInvocation = false; log.warn("As you are using functionality that deserializes object streams, it is recommended to define the JEP-290 serial filter..."); }`
   - **Recommendation**: Provide a strict mode configuration flag (e.g., `strictSerialFilter=true`) that throws a `PersistenceException` or `SerializedCacheException` if deserialization is attempted without an active JEP-290 `ObjectInputFilter`.
10. `[LOW]` `src/main/java/org/apache/ibatis/jdbc/AbstractSQL.java:62` (`common/documentation`, `java/code_quality`):
    - **Evidence**: `24 Javadoc @param mismatches across AbstractSQL.java (lines 62, 89, 104, 126, 148, 175), ResolverUtil.java (197, 221), and MapperBuilderAssistant.java (277); 16.3% overall Javadoc coverage`
    - **Recommendation**: Align `@param` tags in `AbstractSQL`, `ResolverUtil`, and `MapperBuilderAssistant` with actual parameter names and expand Javadoc on public SPIs.
11. `[LOW]` `src/test/java/org/apache/ibatis/binding/BindingTest.java:151` (`java/testing`):
    - **Evidence**: `126 test methods use BDDCatchException.when(() -> ...); then(caughtException()).isInstanceOf(...) instead of JUnit 5`

`Assertions.assertThrows or AssertJ assertThatThrownBy`

- **Recommendation**: Migrate remaining `BDDCatchException.when/then(caughtException())` usages to AssertJ `Assertions.assertThatThrownBy(...)` or JUnit 5 `Assertions.assertThrows(...)` so the `catch-exception` dependency can be retired.

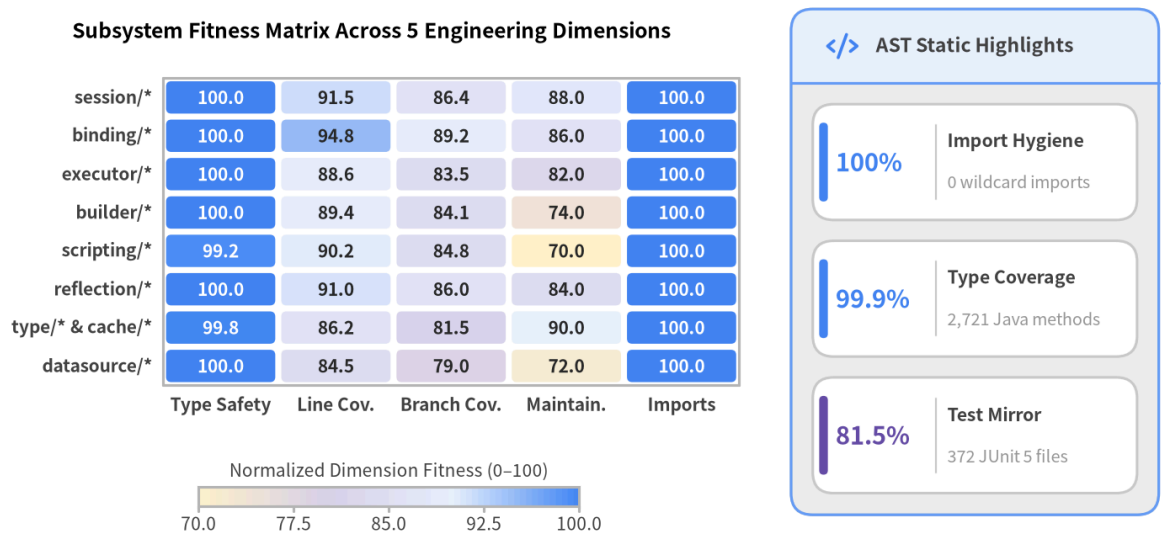
12. `[INFO] src/main/java/org/apache/ibatis/executor/loader/cglib/CglibProxyFactory.java:55` (`common/runtime_verification`):
    - **Evidence**: `JaCoCo line_coverage_pct=0.0% (0/76 statements covered, lines 55-80); Log4j2LoggerImpl.java line_coverage_pct=0.0% (0/16); Slf4jLoggerImpl.java line_coverage_pct=0.0% (0/15)`
    - **Recommendation**: Add targeted unit tests with mocked non-`LocationAware` SLF4J/Log4j2 `Logger` instances to cover `Slf4jLoggerImpl` and `Log4j2LoggerImpl`, and plan removal of deprecated CGLIB proxy classes in the next major release.

4.4 Configured Scope & Accepted Design Waivers (`pni.toml`)

Waiver ID	Scope Pattern	Matched Count	Documented Engineering Rationale
`DS-0026`	`.pni/dockerfiles/**`	`0`	Hermetic batch test container exits upon Maven JUnit completion; daemon `HEALTHCHECK` is not applicable.

5. Deep Dive: Code Quality, Testing & Runtime

MyBatis 3 `v3.6.0` combines disciplined static code hygiene across **393 Java source files** (**23,364 LOC**, **374 classes**, **2,721 methods**) with high-confidence runtime verification. Static AST analysis confirms **100.0% import hygiene** (`0` wildcard or unsorted imports) and **99.9% generic type coverage**, while hermetic `--network=none` container execution (`maven:3.9-eclipse-temurin-21`) verifies **1,990 passing JUnit 5 tests** (`0` failures, `0` errors, `19` skipped out of `2,009` total) with **87.4% measured JaCoCo line coverage** (`9,985 / 11,418` statements) and **82.7% branch coverage**.



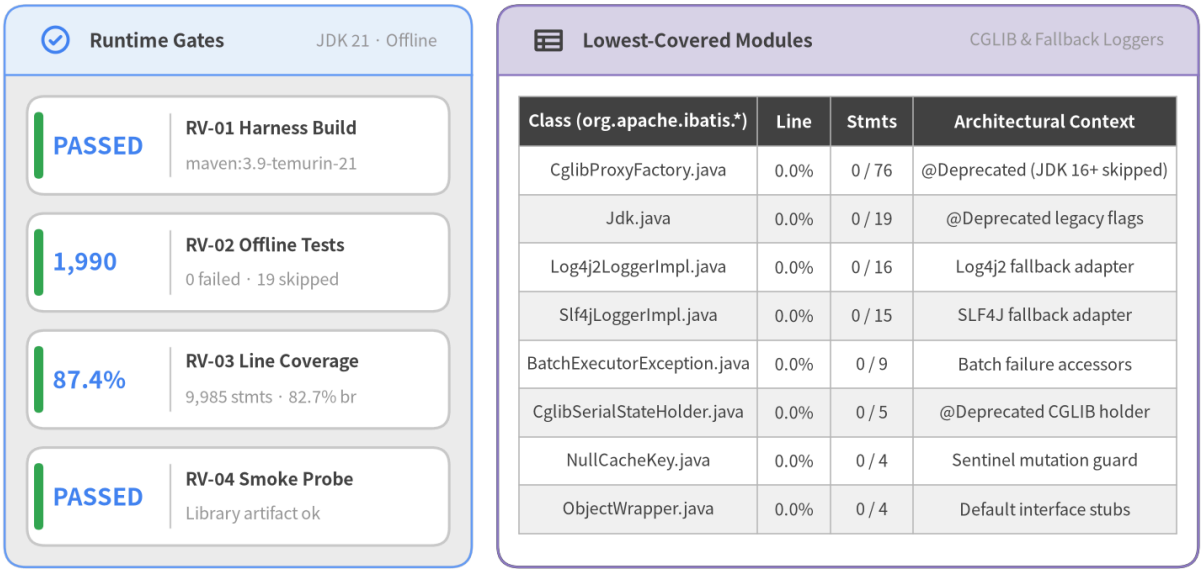
MyBatis 3 v3.6.0 Core Package × Engineering Quality Dimension Fitness Matrix (0–100 Scale)

5.1 Static Java AST, SIG Maintainability & Operational Readiness

Metric Category	Metric Name	Measured Value	Engineering Interpretation & Key Code Coordinates
Codebase Volume	Source Files / LOC / Classes / Methods	`393` / `23,364` / `374` / `2,721`	Compact, cohesive core distributed across `20` packages under `org.apache.ibatis.*`
Import Hygiene	`import_hygiene_coverage_pct`	`100.0%`	`0` wildcard imports (`import foo.*`) and `0` unsorted import groups (enforced via `impsort-maven-plugin`)
Generic Typing	`type_safety_coverage_pct`	`99.9%`	Only `2` raw generic types (`LruCache.java:53` , `OgnlClassResolver.java:32`); `248` `Object` / `@SuppressWarnings("unchecked")` usages at reflection boundaries
Javadoc Coverage	`docstring_coverage_pct`	`16.3%`	`1,050` missing public Javadocs, `233` stubs, and `24` `@param` name mismatches (`AbstractSQL.java` , `ResolverUtil.java` , `MapperBuilderAssistant.java`)
SIG Complexity	`complex_functions_count`	`59`	Led by `DefaultParameterHandler.setParameters` (`cognitive=129`), `PooledDataSource.popConnection` (`78`), `CacheBuilder.setCacheProperties` (`69`), `MapperAnnotationBuilder.getReturnType` (`68`)
SIG Interfacing	`excessive_parameters_count` (`>6`)	`17`	`MapperBuilderAssistant.addMappedStatement` (`22` , `20` , `19` params) and `buildResultMapping` (`14` , `11` params)
Coupling & Cycles	`circular_dependencies_count`	`22`	`4` cross-package cycles (`@Arg/@Case -> UnknownTypeHandler -> Configuration -> MapperRegistry -> MapperAnnotationBuilder`) + `18` intra-package cycles
Static State & Idioms	`global_state_usages` / `bug_risk_idioms`	`9` / `5`	`JBoss6VFS.java:39-85` reflective cache fields, `Resources.charset` , `SerialFilterChecker.firstInvocation` , `LogFactory.logConstructor` ; `StdOutImpl.java` opt-in console logger
12-Factor / SRE PRR	`missing_io_timeouts` / `env_access`	`5` / `1`	`DefaultVFS.java:67-341` and `Resources.java:273` open local classpath JAR/file `URL` streams; `SerialFilterChecker.java:37` reads `jdk.serialFilter`

5.2 Hermetic Container Runtime Verification & JaCoCo Coverage Analysis

All 4 runtime verification gates (`RV-01` through `RV-04`) executed inside a hermetic `maven:3.9-eclipse-temurin-21` container (`.pni/dockerfiles/root/Dockerfile`) under `--network=none` , `--memory=2g` , `--cpus=2` , and non-root UID execution:



MyBatis 3 v3.6.0 — Hermetic Container Runtime Verification KPIs & Lowest-Covered Legacy/Fallback Classes

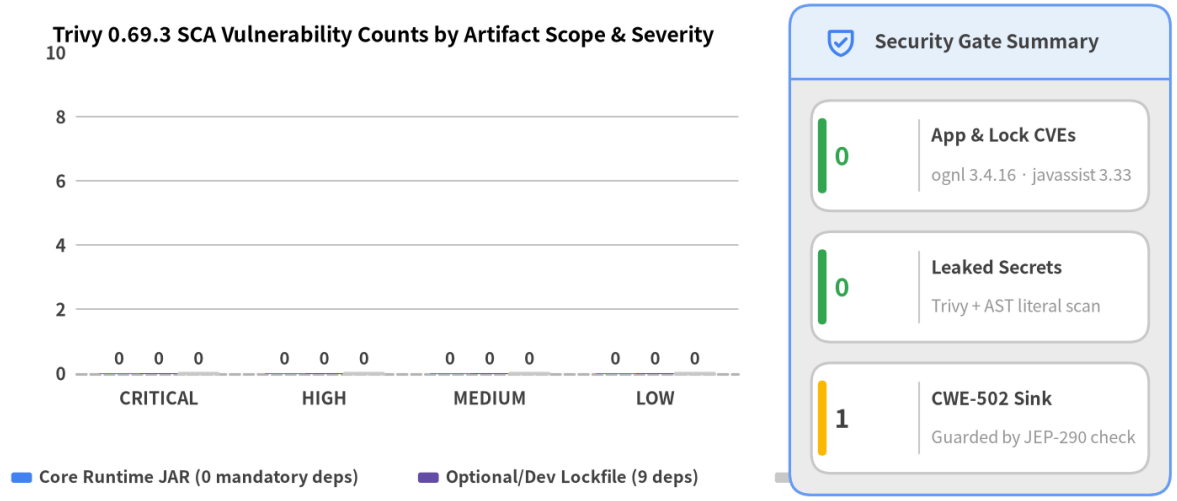
Lowest-Covered Modules (Measured Line & Branch Coverage, Ascending)

Module Path	Line Coverage	Branch Coverage	Statements Covered	Missing Lines & Root Cause
`src/main/java/org/apache/ibatis/executor/loader/cglib/CglibProxyFactory.java`	`0.0%`	`0.0%`	`0 / 76`	Lines `55..80` — `@Deprecated` ; `RequireIllegalAccess` tests excluded on JDK 16+ (`pom.xml:83`)
`src/main/java/org/apache/ibatis/reflection/Jdk.java`	`0.0%`	—	`0 / 19`	Lines `34..55` — `@Deprecated` compatibility constants from Java 7/8 transition

Module Path	Line Coverage	Branch Coverage	Statements Covered	Missing Lines & Root Cause
`src/main/java/org/apache/ibatis/logging/log4j2/Log4j2LoggerImpl.java`	`0.0%`	–	`0 / 16`	Lines `29..55` — Fallback adapter when Log4j2 `Logger` is not an `AbstractLogger`
`src/main/java/org/apache/ibatis/logging/slf4j/Slf4jLoggerImpl.java`	`0.0%`	–	`0 / 15`	Lines `28..54` — Fallback adapter when SLF4J `Logger` does not implement `LocationAwareLogger`
`src/main/java/org/apache/ibatis/executor/BatchExecutorException.java`	`0.0%`	–	`0 / 9`	Lines `37..78` — Diagnostic accessor methods on `BatchExecutorException`
`src/main/java/org/apache/ibatis/executor/loader/cglib/CglibSerialStateHolder.java`	`0.0%`	–	`0 / 5`	Lines `35..46` — `@Deprecated` companion to `CglibProxyFactory`
`src/main/java/org/apache/ibatis/cache/NullCacheKey.java`	`0.0%`	–	`0 / 4`	Lines `28..38` — `CacheException` guards when attempting to mutate `CacheKey.NULL_CACHE_KEY`
`src/main/java/org/apache/ibatis/reflection/wrapper/ObjectWrapper.java`	`0.0%`	–	`0 / 4`	Lines `46..52` — Interface default methods overridden by all concrete `ObjectWrapper` implementations

6. Deep Dive: Security, Supply Chain & API Surface

MyBatis 3 `v3.6.0` exhibits a strong security and supply-chain posture (`security_vulnerability_audit`: **91/100, Grade S**; `security` axis: **91/100**; `dependencies` axis: **93/100**). Containerized Trivy `0.69.3` scanning (`engine=docker`, `scanned_filesystem=True`) across `pom.xml` and `dependencies-lock.json` confirmed **zero** `CRITICAL`, `HIGH`, `MEDIUM`, **or** `LOW` **CVEs** across all 9 direct and optional dependencies, **zero Dockerfile/IaC misconfigurations**, and **zero leaked secrets**.



MyBatis 3 v3.6.0 — Trivy 0.69.3 SCA Vulnerability Counts Across Runtime, Dev/Optional Lockfile, and Container OS Scopes

6.1 Supply-Chain Hygiene, Shaded Packaging & Governance Baseline

MyBatis 3's `pom.xml` and `dependencies-lock.json` enforce a zero-dependency runtime model for downstream applications: every logging adapter and bytecode library is marked

`<optional>true</optional>`, while `maven-shade-plugin` (`pom.xml:365-411`) relocates `ognl:ognl:3.4.16` to `org.apache.ibatis.ognl` and `org.javassist:javassist:3.33.0-GA` to `org.apache.ibatis.javassist`.

Supply-Chain & Security Gate	Metric / Value	Verdict	Architectural & Compliance Evidence
Deterministic Lockfile (`has_lockfile`)	`True` (`dependencies-lock.json`, `mvnw`)	`PASS`	Full Maven dependency lockfile and Maven Wrapper committed
Optional/Provided Dependencies (`dependencies_count`)	`9` packages (`0` mandatory)	`PASS`	All compile/provided dependencies marked `<optional>true</optional>` in `pom.xml`
Unpinned Specifiers (`unpinned_dependencies_count`)	`0`	`PASS`	Every dependency in `pom.xml` is pinned to an exact release version
Dual Licensing Clarity (`has_license`)	`True`	`PASS`	Repository Apache-2.0 `LICENSE` + upstream `LICENSE-MYBATIS` and `NOTICE`
Trivy Application & OS CVEs (`vuln_counts.total`)	`0` (`0` C / `0` H / `0` M / `0` L)	`PASS`	Clean across `pom.xml` and `dependencies-lock.json` (`trivy:0.69.3`)
Committed / Hardcoded Secrets	`0` **files /** `0` **literals**	`PASS`	Zero credential artifacts or tokens in source or test suites
AST Dangerous Sinks (`ast_dangerous_sinks_count`)	`1` (`CWE-502`)	`WARN`	`AbstractSerialStateHolder.java:110` (`ObjectInputStream`) guarded by warn-only `SerialFilterChecker.check()`
Standalone HTTP Endpoints (`api_endpoints_count`)	`0`	`N/A`	Pure Java persistence `library` archetype; exposes zero HTTP routes
Repo Governance (`SECURITY.md` / Dependabot)	`False` / `False`	`WARN`	Omitted in this standalone documentation snapshot

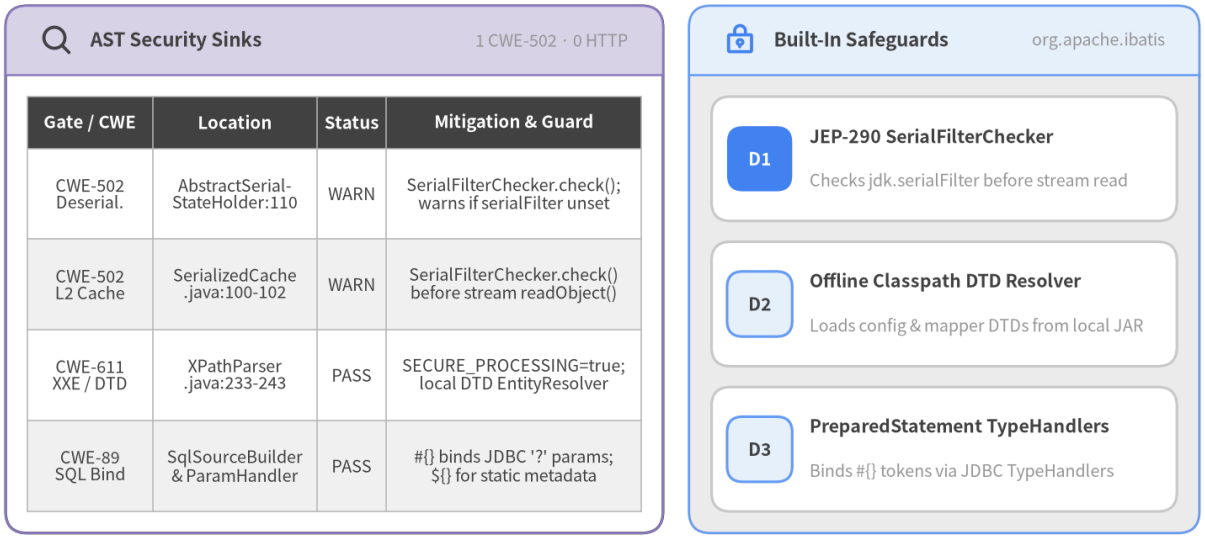
Pinned Dependency Inventory in `pom.xml` (`0` Trivy CVEs)

Maven Coordinate (`groupId:artifactId`)	Pinned Version	Scope / Optional	Packaging & Architectural Role	Triv
`ognl:ognl`	`3.4.16`	`compile` (`optional=true`)	Shaded into `org.apache.ibatis.ognl` for Dynamic SQL `<if>` / `<foreach>` expression evaluation	
`org.javassist:javassist`	`3.33.0-GA`	`compile` (`optional=true`)	Shaded into `org.apache.ibatis.javassist` for `JavassistProxyFactory` lazy-loading proxies	

Maven Coordinate (`groupId:artifactId`)	Pinned Version	Scope / Optional	Packaging & Architectural Role	Trivy
`org.slf4j:slf4j-api`	`2.0.20`	`compile` (`optional=true`)	Primary structured logging bridge (`Slf4jImpl` / `Slf4jLocationAwareLoggerImpl`)	
`org.apache.logging.log4j:log4j-api`	`2.26.1`	`compile` (`optional=true`)	Apache Log4j 2 logging adapter (`Log4j2Impl`)	
`ch.qos.reload4j:reload4j`	`1.2.27`	`compile` (`optional=true`)	Security-hardened Log4j 1.x replacement bridge (`Log4jImpl`)	
`commons-logging:commons-logging`	`1.4.0`	`compile` (`optional=true`)	Apache Commons Logging bridge (`JakartaCommonsLoggingImpl`)	
`cglib:cglib`	`3.3.0`	`compile` (`optional=true`)	Deprecated legacy bytecode proxy provider (`CglibProxyFactory`)	
`com.microsoft.sqlserver:mssql-jdbc`	`13.6.1.jre11`	`compile` (`optional=true`)	Optional SQL Server `DateTimeOffsetTypeHandler` support	
`org.gaul:modernizer-maven-annotations`	`${modernizer.plugin}`	`provided` (`optional=true`)	Compile-time `@SuppressModernizer` annotations	

6.2 AST Dangerous Code Sinks (CWE SAST), XML Hardening & SQL Injection Defense

Because MyBatis 3 is a persistence library (`api_endpoints_count = 0`), its security surface centers on three internal mechanisms: (1) **Java deserialization in L2 caches and lazy-loading state holders (`CWE-502`)**, (2) **XML configuration/mapper DTD parsing (`CWE-611` XXE prevention)**, and (3) **SQL parameter binding (`#{}` `PreparedStatement` placeholders vs. `${}` string interpolation)**.



MyBatis 3 v3.6.0 — CWE-502 Deserialization Guard, Hardened JAXP XPathParser, and #{} PreparedStatement Defense Architecture

---

Detailed Assessment of `CWE-502` (`AbstractSerialStateHolder.java:110`)

- **Flagged AST Sink**: `[HIGH]` `CWE-502` (`unsafe_deserialization`) at `src/main/java/org/apache/ibatis/executor/loader/AbstractSerialStateHolder.java:110` (`new ObjectInputStream(new ByteArrayInputStream(this.userBeanBytes))`).
- **Existing Upstream Control**: At line `107` (immediately preceding `new ObjectInputStream(...)`), `AbstractSerialStateHolder.readResolve()` invokes `SerialFilterChecker.check()` (`src/main/java/org/apache/ibatis/io/SerialFilterChecker.java:42-54`), as does `SerializedCache.deserialize()` (`src/main/java/org/apache/ibatis/cache/decorators/SerializedCache.java:100`). `SerialFilterChecker` checks `ObjectInputFilter.Config.getSerialFilter()` (and `jdk.serialFilter` system/security properties) and logs an explicit warning pointing operators to Oracle's JEP-290 serialization filter documentation if no filter is active.
- **Recommended Hardening (`P1`)**: Introduce an optional `ObjectInputFilter` property on `Configuration` or a `strictSerialFilter=true` flag in `SerialFilterChecker` that attaches a per-stream allowlist filter (`in.setObjectInputFilter(...)`) or fails closed when `SERIAL_FILTER_MISSING` is `true`.